

Индивидуальный проект

Этап №4

Сергеев Даниил Олегович

2026-05-02

Содержание I

- 1 Информация
- 2 Цель работы
- 3 Ход выполнения лабораторной работы
- 4 Вывод

Раздел 1

Информация

- Сергеев Даниил Олегович

- Сергеев Даниил Олегович
- Студент

- Сергеев Даниил Олегович
- Студент
- Направление: Прикладная информатика

- Сергеев Даниил Олегович
- Студент
- Направление: Прикладная информатика
- Российский университет дружбы народов

- Сергеев Даниил Олегович
- Студент
- Направление: Прикладная информатика
- Российский университет дружбы народов
- 1132246837@pfur.ru

- Сергеев Даниил Олегович
- Студент
- Направление: Прикладная информатика
- Российский университет дружбы народов
- 1132246837@pfur.ru
- <https://github.com/FrigatZero>

Раздел 2

Цель работы

Целью данной работы является использование базового сканера безопасности веб-сервера nikto в рамках индивидуального проекта.

Раздел 3

Ход выполнения лабораторной работы

Запуск DVWA

Будем тестировать nikto на основе DVWA, установленного на прошлых этапах. Откроем терминал от имени администратора и запустим службы `apache2` и `mariadb`.

```
service apache2 start
service mariadb start
service apache2 status | head
service mariadb status | head
```

Запуск DVWA

```
dosergeev@dosergeev: ~  
Session Actions Edit View Help  
[dosergeev@dosergeev]~  
$ service apache2 start  
[dosergeev@dosergeev]~  
$ service mariadb start  
[dosergeev@dosergeev]~  
$  
[dosergeev@dosergeev]~  
$ service apache2 status | head  
● apache2.service - The Apache HTTP Server  
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; preset: disabled)  
   Active: active (running) since Sat 2026-05-02 17:56:59 MSK; 15min ago  
   Invocation: d8bd90a57dae40b69b21cf4f08911f76  
   Docs: https://httpd.apache.org/docs/2.4/  
   Process: 29642 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)  
   Main PID: 29645 (apache2)  
   Tasks: 8 (limit: 4443)  
   Memory: 41.1M (peak: 41.3M)  
   CPU: 23.647s  
[dosergeev@dosergeev]~  
$ service mariadb status | head  
● mariadb.service - MariaDB 11.8.3 database server  
   Loaded: loaded (/usr/lib/systemd/system/mariadb.service; disabled; preset: disabled)  
   Active: active (running) since Sat 2026-05-02 17:57:25 MSK; 14min ago  
   Invocation: a30b798bc34545d887c699d0dd4a1877  
   Docs: man:mariadb(8)  
         https://mariadb.com/kb/en/library/systemd/  
   Process: 29900 ExecStartPre=/usr/bin/install -m 755 -o mysql -g root -d /var/run/mysqld (code=exited, status=0/SUCCESS)  
   Process: 29902 ExecStartPre=/bin/sh -c [ ! -e /usr/bin/galera_recovery ] && VAR=  VAR=`usr/bin/galera_recovery`  
   Process: 29987 ExecStartPost=/bin/rm -f /run/mysqld/wsrep-start-position (code=exited, status=0/SUCCESS)  
   Process: 29989 ExecStartPost=/etc/mysql/debian-start (code=exited, status=0/SUCCESS)  
[dosergeev@dosergeev]~  
$
```



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript Attacks

Authorisation Bypass

Open HTTP Redirect

Cryptography

API

DVWA Security

PHP Info

About

Welcome to Damn Vulnerable Web Application!

Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers to learn about web application security in a controlled class room environment.

The aim of DVWA is to **practice some of the most common web vulnerabilities**, with **various levels of difficulty**, with a simple straightforward interface.

General Instructions

It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. There is not a fixed object to complete a module; however users should feel that they have successfully exploited the system as best as they possible could by using that particular vulnerability.

Please note, there are **both documented and undocumented vulnerabilities** with this software. This is intentional. You are encouraged to try and discover as many issues as possible.

There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.

WARNING!

Damn Vulnerable Web Application is damn vulnerable! **Do not upload it to your hosting provider's public html folder or any Internet facing servers**, as they will be compromised. It is recommend using a virtual machine (such as [VirtualBox](#) or [VMware](#)), which is set to NAT networking mode. Inside a guest machine, you can download and install [XAMPP](#) for the web server and database.

Disclaimer

We do not take responsibility for the way in which any one uses this application (DVWA). We have made the purposes of the application clear and it should not be used maliciously. We have given warnings & taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

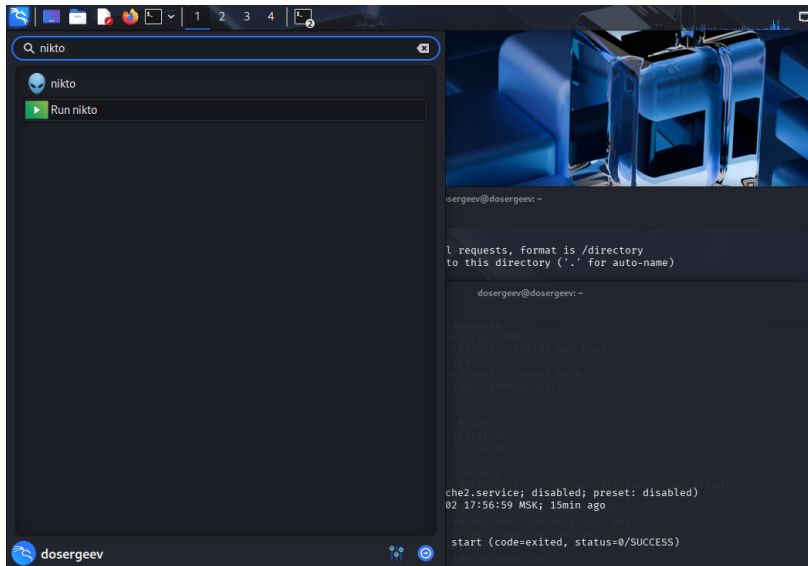
More Training Resources

DVWA aims to cover the most commonly seen vulnerabilities found in today's web applications. However there

nikto - базовый сканер безопасности веб-сервера. Он сканирует и обнаруживает уязвимости в веб-приложениях, обычно вызванные неправильной конфигурацией на самом сервере, файлами, установленными по умолчанию, и небезопасными файлами, а также устаревшими серверными приложениями.

Запустим сканер из поискового меню. Откроется терминал со справкой к возможным опциям nikto.

Использование nikto



Использование nikto

```
dosergeev@dosergeev: ~  
Session Actions Edit View Help  
$ nikto --Help  
  
Options:  
-ask+          Whether to ask about submitting updates  
                yes Ask about each (default)  
                no  Don't ask, don't send  
                auto Don't ask, just send  
-check6        Check if IPv6 is working (connects to ipv6.google.com or value set in nikto.conf)  
-Cgkdirs+      Scan these CGI dirs: "none", "all", or values like "/cgi/ /cgi-a/"  
-config+       Use this config file  
-Display+      Turn on/off display outputs:  
                1 Show redirects  
                2 Show cookies received  
                3 Show all 200/OK responses  
                4 Show URLs which require authentication  
                D Debug output  
                E Display all HTTP errors  
                P Print progress to STDOUT  
                S Scrub output of IPs and hostnames  
                V Verbose output  
-dbcheck        Check database and other key files for syntax errors (disabled)  
-evasion+       Encoding technique:  
                1 Random URI encoding (non-UTF8)  
                2 Directory self-reference (../)  
                3 Premature URL ending  
                4 Prepend long random string  
                5 Fake parameter  
                6 TAB as request spacer  
                7 Change the case of the URL  
                8 Use Windows directory separator (\)  
                A Use a carriage return (0x0d) as a request spacer  
                B Use binary value 0x0b as a request spacer  
-followredirects Follow 3xx redirects to new location  
-Format+        Save file (-o) format:  
                csv Comma-separated-value  
                json JSON Format
```

Рисунок 4: Терминал nikto

Использование nikto

```
(dosergeev@dosergeev)-[~]
$ nikto -h 127.0.0.1 -p 80
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Start Time: 2026-05-02 17:58:24 (GMT3)

+ Server: Apache/2.4.65 (Debian)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mi
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 645014baa4dc0, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: POST, OPTIONS, HEAD, GET .
+ ///etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561
+ /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found
+ /wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found
+ /assets/mobirise/css/meta.php?filesrc=: A PHP backdoor file manager was found.
+ /login.cgi?cli=aa%20aa%27cat%20/etc/hosts: Some D-link router remote command execution.
+ /shell?cat=/etc/hosts: A backdoor was identified.
+ 8074 requests: 0 error(s) and 15 item(s) reported on remote host
+ End Time: 2026-05-02 17:58:42 (GMT3) (18 seconds)

+ 1 host(s) tested
```

Рисунок 5: Вывод nikto

Программа запустит анализ и выведет сводку для каждой уязвимости, которую найдет. Nikto нашел следующие уязвимости:

- Отсутствует заголовок `X-Frame-Options`, что делает сайт уязвимым к атакам clickjacking.

Программа запустит анализ и выведет сводку для каждой уязвимости, которую найдет. Nikto нашел следующие уязвимости:

- Отсутствует заголовок `X-Frame-Options`, что делает сайт уязвимым к атакам clickjacking.
- Не установлен заголовок `X-Content-Type-Options`, что может позволить браузеру интерпретировать контент неверного MIME-типа.

Программа запустит анализ и выведет сводку для каждой уязвимости, которую найдет. Nikto нашел следующие уязвимости:

- Отсутствует заголовок `X-Frame-Options`, что делает сайт уязвимым к атакам clickjacking.
- Не установлен заголовок `X-Content-Type-Options`, что может позволить браузеру интерпретировать контент неверного MIME-типа.
- Сервер Apache раскрывает inode через заголовок `ETag`, что может привести к утечке информации.

Программа запустит анализ и выведет сводку для каждой уязвимости, которую найдет. Nikto нашел следующие уязвимости:

- Отсутствует заголовок `X-Frame-Options`, что делает сайт уязвимым к атакам clickjacking.
- Не установлен заголовок `X-Content-Type-Options`, что может позволить браузеру интерпретировать контент неверного MIME-типа.
- Сервер Apache раскрывает inode через заголовок `ETag`, что может привести к утечке информации.
- Доступные HTTP-методы: POST, OPTIONS, HEAD и GET.

- Обнаружена возможность чтения системных файлов через добавление лишнего слеша в URL (например, `//etc/hosts`).

- Обнаружена возможность чтения системных файлов через добавление лишнего слеша в URL (например, `//etc/hosts`).
- Страница `/server-status` раскрывает информацию о сервере Apache.

- Обнаружена возможность чтения системных файлов через добавление лишнего слеша в URL (например, `//etc/hosts`).
- Страница `/server-status` раскрывает информацию о сервере Apache.
- По пути многих адресов найден PHP-бэкдор-файловый менеджер.

- Обнаружена возможность чтения системных файлов через добавление лишнего слеша в URL (например, `//etc/hosts`).
- Страница `/server-status` раскрывает информацию о сервере Apache.
- По пути многих адресов найден PHP-бэkdор-файловый менеджер.
- Скрипт `login.cgi` с параметром `cli=aa%20aa%27cat%20/etc/hosts` указывает на возможность удалённого выполнения команд на некоторых роутерах D-Link.

- Обнаружена возможность чтения системных файлов через добавление лишнего слеша в URL (например, `//etc/hosts`).
- Страница `/server-status` раскрывает информацию о сервере Apache.
- По пути многих адресов найден PHP-бэкдор-файловый менеджер.
- Скрипт `login.cgi` с параметром `cli=aa%20aa%27cat%20/etc/hosts` указывает на возможность удалённого выполнения команд на некоторых роутерах D-Link.
- Обнаружен бэкдор через URL `/shell?cat=/etc/hosts`.

Раздел 4

Вывод

В результате выполнения лабораторной работы был испытан базовый сканер безопасности веб-сервера nikto на основе уязвимого DVWA. Были исследованы возможные уязвимости, которые нашлись внутри данного веб-приложения.